

Unit 5: Study Guide - Understand legislation and ethical conduct within cyber security

1.1 How Legislation Impacts on Cyber Security

Key Points:

- **Cyber security legislation** refers to laws designed to protect data, networks, and IT systems from cyber threats.
- Legislation affects organisations by requiring compliance with data protection, privacy, and security protocols.

Important Laws & Regulations:

- **GDPR (General Data Protection Regulation)** – EU law protecting personal data.
- **Computer Misuse Act (UK)** – Criminalises unauthorised access, modification, or impairment of computer systems.
- **Data Protection Act (UK)** – Governs how personal data is processed and stored.
- **Cybersecurity Act (various countries)** – Sets standards for protecting critical infrastructure.

Impact on Cyber Security:

- Ensures organisations implement security controls.
- Holds organisations accountable for breaches.
- Encourages regular audits and risk assessments.
- Drives the creation of internal policies and employee training programs.

Example:

A company storing EU citizen data must comply with GDPR; failure can lead to fines up to €20 million or 4% of global turnover.

1.2 Trends in International Law for Cyberspace

Key Points:

- International cyber law is developing to address cross-border cybercrime.
- Countries are collaborating to create frameworks for cybersecurity standards and conflict resolution.

Current Trends:

- **Mutual Legal Assistance Treaties (MLATs)** – Facilitate cross-border investigations.
- **UN GGE (United Nations Group of Governmental Experts)** – Develops norms for responsible state behaviour in cyberspace.

- **Budapest Convention on Cybercrime** – First international treaty addressing computer crime and cooperation.
- **Focus on cyber warfare** – Countries developing norms to prevent attacks on critical infrastructure.

Impact on Cyber Security Professionals:

- Must understand international laws when working with global clients or data.
- Awareness of legal consequences of cyberattacks across borders.
- Compliance with international standards helps in global business operations.

2.1 ISO Standards Related to Cyber Security

Key Points:

- **ISO (International Organisation for Standardisation)** creates globally recognised standards.
- ISO standards provide frameworks for managing cybersecurity risks and ensuring data integrity.

Important ISO Standards:

- **ISO/IEC 27001** – Information Security Management System (ISMS).
- **ISO/IEC 27002** – Guidelines for organisational information security standards.
- **ISO/IEC 27017** – Security controls for cloud services.
- **ISO/IEC 27032** – Cybersecurity guidelines for protecting networks and critical infrastructure.

Benefits of ISO Standards:

- Provides structured approach to security management.
- Helps organisations identify and mitigate risks.
- Increases stakeholder confidence and compliance with laws.
- Facilitates audits and certification.

2.2 How ISO Standards Are Used to Support Cyber Security

Key Points:

- ISO standards guide organisations in implementing cybersecurity best practices.

Implementation Examples:

- **Risk Assessment** – ISO 27001 requires identifying risks to information assets.
- **Security Controls** – ISO 27002 provides detailed guidance on controls like access management, encryption, and incident response.

- **Audits & Certification** – Compliance demonstrates commitment to cybersecurity and can be externally validated.

Impact on Cyber Security Professionals:

- Helps in creating policies and procedures.
- Ensures security practices are aligned with international best practices.
- Supports regulatory compliance and reduces vulnerability to breaches.

3.1 Ethical Conduct Within Cyber Security

Key Points:

- Ethical conduct is about acting responsibly, legally, and professionally in cyber operations.
- Ethical behaviour builds trust with clients, employers, and the public.

Examples of Ethical Conduct:

- Protecting user privacy and sensitive data.
- Reporting vulnerabilities rather than exploiting them.
- Following laws, regulations, and organisational policies.
- Using skills to strengthen cybersecurity defences.

Professional Guidelines:

- Codes of ethics from organisations like (ISC)² or BCS.
- Avoiding conflicts of interest and maintaining integrity.

3.2 Unethical Conduct Within Cyber Security

Key Points:

- Unethical conduct can lead to legal consequences, reputational damage, and security breaches.

Examples of Unethical Conduct:

- Hacking or unauthorised access to systems.
- Selling sensitive information or exploiting vulnerabilities for personal gain.
- Ignoring security policies or intentionally exposing systems to risk.
- Plagiarism of software or malicious coding.

Consequences:

- Legal prosecution (fines, imprisonment).
- Loss of professional certification or job.

- Damage to personal and organisational reputation.
-